

Remote Code Execution (RCE) via Web Shell Upload

Summary

A Remote Code Execution (RCE) vulnerability was identified in a file upload functionality that allowed arbitrary PHP files to be uploaded and executed on the target server. By uploading a malicious PHP web shell, it was possible to execute server-side code and access sensitive files stored on the system.

Vulnerability Details

Vulnerability Type: Remote Code Execution (RCE)

Severity: Critical

Attack Vector: Unrestricted File Upload

Affected Component: File Upload Functionality

Description

The application failed to properly validate uploaded files, allowing an attacker to upload executable PHP code. After uploading a PHP file, the server processed and executed the code, resulting in Remote Code Execution.

To demonstrate impact, a PHP file was uploaded containing code that read a sensitive file from the server:

```
<?php
echo file_get_contents('/home/carlos/secret');
?>
```

Upon accessing the uploaded file through the browser, the application executed the PHP code and disclosed the contents of the sensitive file.

Proof of Concept (PoC)

1. Navigate to the file upload functionality.
2. Upload a PHP web shell containing server-side PHP code.
3. Obtain the URL of the uploaded file.
4. Access the uploaded file through the browser.
5. Observe that the server executes the PHP code.
6. Read sensitive data from `/home/carlos/secret`.

Impact

Successful exploitation allows an attacker to:

- Execute arbitrary code on the server.
- Access sensitive files and configuration data.
- Potentially obtain application secrets and credentials.
- Escalate privileges depending on server configuration.
- Achieve full compromise of the affected application.

Risk Rating

CVSS v3.1: 9.8 (Critical)

Evidence

- Successful upload of executable PHP file.
- Execution of attacker-controlled code on the server.
- Retrieval of sensitive data from `/home/carlos/secret`.
- Screenshot evidence captured during exploitation.

Remediation

- Restrict uploads to approved file types only.
- Store uploaded files outside the web root.
- Disable execution permissions on upload directories.
- Implement strict server-side validation.
- Rename uploaded files and use secure random identifiers.
- Employ allowlists instead of blocklists for file extensions.
- Configure the web server to prevent execution of uploaded content.

Conclusion

The application is vulnerable to Remote Code Execution through unrestricted file upload. Exploitation enables arbitrary server-side code execution and access to sensitive information, making this a Critical severity issue that should be remediated immediately.